

MASTER'S THESIS PROPOSAL

Automated Blast Radius Measurement & Reduction

Evaluating cloud lateral movement and access paths across AWS workloads.

Student: **Soumik Shadman** (11154499)

Program: **M.Sc. Communication Systems and Networks**

Institution: **Technische Hochschule Köln (TH Köln)**

Company Partner: **Dyn Media GmbH**

Motivation & Problem

⚠ The AWS Security Risk

- ✓ **Excessive Permissions:** Workloads often have access to far more services than they actually need to function.
- ✓ **Unchecked Spread:** Compromising one resource can trigger a large, unchecked lateral movement attack.
- ✓ **Visibility Gaps:** Organizations lack a direct way to visualize the real logical reachability of threats.

✖ The Industry Challenge

- ✓ **No Unified Metric:** Security teams cannot measure the complete blast radius with a single direct score.
- ✓ **Static Scan Limitations:** Common tools check basic configurations but fail to model complete network/IAM paths.
- ✓ **No Control Priority:** Difficult to evaluate which exact configuration changes bring the highest risk reduction.

Research Objectives

Graph Model

Define a solid graph-based math model representing true AWS workload link states.

Custom Scanner

Build an automated Python discovery engine to parse live AWS resources and map paths.

Control Testing

Apply step-by-step hardening changes to measure control effectiveness and validate the model.

Research Questions

🔍 RQ1 & RQ2

- ➔ **Modeling Reach:** How can AWS blast radius be formally represented and automatically scanned?
- ➔ **Control Impact:** Which specific cloud security controls yield the greatest reduction in the blast radius score?

🔗 RQ3 & RQ4

- ➔ **Architecture Variance:** Does control effectiveness differ between traditional (EC2) and serverless architectures?
- ➔ **Model Validation:** How accurately does the mathematical graph match real-world scanning measurements?

Blast Radius Model

Graph Formula $G = (V, E)$

Environments are mapped as directed attack graphs:

- ✔ **Vertices (V):** Active cloud resources, databases, endpoints, and external routes.
- ✔ **Edges (E):** Connections mapped through network routing, IAM policies, and metadata access.

QUANTITATIVE FORMULA

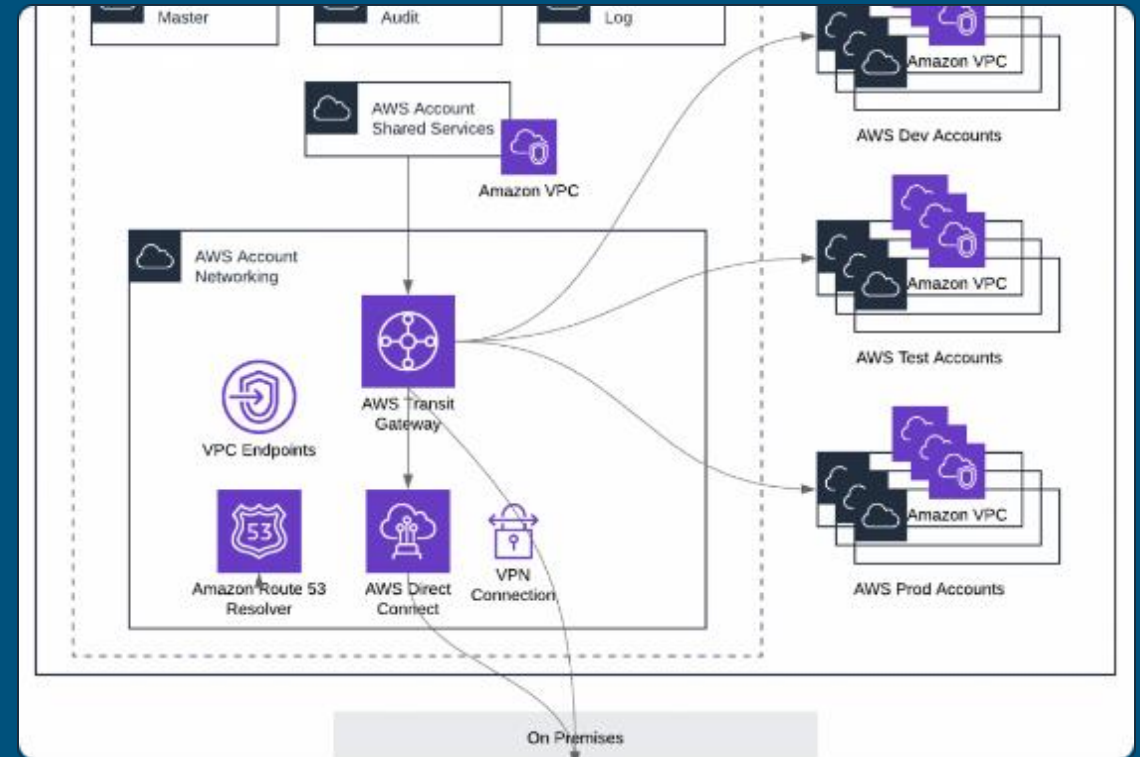
$$BR(v) = \frac{|R(v)|}{|V \setminus \{v\}|}$$

Automated Scanner

Core Python Engine

A custom-built Python security framework that automatically performs logical analysis:

- ✓ **Resource Discovery:** Interacts with AWS APIs using boto3 to fetch real configurations.
- ✓ **Relationship Mapping:** Translates IAM boundaries and security groups into graph structures via networkx.



Security Controls

Primary Controls

- ✓ **IMDSv2 Enforcement:** Limits session token theft to protect compute identity credentials.
- ✓ **Database Firewalls:** Isolates persistent data systems to dedicated backend subnets.

Secondary Controls

- ✓ **Egress Restrictions:** Blocks direct routes to non-business public internet space.
- ✓ **VPC Endpoint Policies:** Scopes API calls to narrow, approved resources.

Dual Validation

Mathematical Prediction

Calculates the logical attack path theoretically using graph-theoretic reachability formulas on configuration structures.

Measured Scanning

Discovers active network links, security rules, and real runtime permissions using the custom Python discovery engine.

Workload Case Studies

☒ WordPress Architecture

Traditional EC2 + RDS + S3 Stack

- ✔ **Security Model:** Highly network-centric (VPC subnets, security groups).
- ✔ **Relevance:** Represents legacy VM deployments running public web applications.

⚡ Article Generator

Serverless Lambda + DynamoDB Stack

- ✔ **Security Model:** Highly identity-centric (IAM roles, service trust boundaries).
- ✔ **Relevance:** Represents modern, microservice-driven, zero-trust workloads.

Timeline & Plan



Risk	Mitigation Plan
Hardening breaks live WordPress service	Test security rules extensively in DEV environments for 1 week before PROD.
IAM calculations are too complex	Utilize IAM Access Analyzer parsed findings as direct graph model inputs.

References & Conclusion

Reference	Academic Link
Stournaras (2023)	"HackerGraph: Creating a Knowledge Graph for Security Assessment of AWS Systems." KTH Royal Institute of Technology.
Ibrahim et al. (2019)	"Attack Graph Generation for Microservice Architecture" (TUMunich, ACM SAC).
Capobianco (2019)	"Employing Attack Graphs for Intrusion Detection" (Penn State, NSPW).

🚩 Conclusion

This research provides a practical, automated model to quantify cloud security posture dynamically. By bridging formal graph representations with live AWS API capabilities, it enables security teams to make highly optimized risk-reduction decisions.